JOURNAL OF CYBERSECURITY

Journal of Cybersecurity, 2025, tyaf020
https://doi.org/10.1093/cybsec/tyaf020

Research Paper

Toward effective cybersecurity management: a hierarchical process model with performance assessment

Marina Liu [1,2,*], Malcolm Shore[1], William Yeoh[3], Frank Jiang[1,2,*], Sherali Zeadally[4,5]

[1]Deakin Cyber Research and Innovation Centre, Deakin University, 221 Burwood Highway, Burwood, VIC 3125, Australia
[2]School of Information Technology, Deakin University, 221 Burwood Highway, Burwood, VIC 3125, Australia
[3]Lee Shau Kee School of Business and Administration, Hong Kong Metropolitan University, Ho Man Tin, Hong Kong SAR
[4]College of Communication and Information, University of Kentucky, 308 Lucille Little Library, Lexington, KY 40506, United States
[5]Imam Abdulrahman bin Faisal University (IAU), Dammam, Saudi Arabia

*Corresponding authors. Marina Liu, E-mail: liumengyin@deakin.edu.au; Frank Jiang; E-mail: frank.jiang@deakin.edu.au; School of Information Technology, Deakin University, 221 Burwood Highway, Burwood, VIC 3125, Australia.

Received 10 October 2024; revised 25 April 2025; accepted 15 July 2025

Abstract

The conventional approach to managing a cybersecurity program typically involves building an Information Security Management System based on one or a combination of security standards. However, this approach is inadequate for meeting the requirements of modern cybersecurity programs. It lacks a systematic and structured method for efficiently managing and comprehensively measuring cybersecurity efforts. In response, we conducted a three-round Delphi study to develop a hierarchical cybersecurity management process model consisting of 6 strategic processes, 11 tactical processes, and 19 operational processes. Based on these findings, we developed the Cybersecurity Management and Performance Assessment model, which helps organizations to assess process maturity and control effectiveness. Our study contributes to the theoretical knowledge in the field of cybersecurity management. By adopting our model, organizations can enhance their cybersecurity assurance and identify pathways to improve the effectiveness and maturity of their cybersecurity programs.

Keywords: cybersecurity management; process model; maturity; effectiveness measurement; Delphi study

Introduction

Organizations build Information Security Management Systems (ISMS) based on security standards, such as ISO 27001 and NIST SP 800–53, to guide the establishment and ongoing operation of their cybersecurity programs [1, 2]. These standards utilize a control-driven, compliance-first approach to information security management. However, as cyber threats evolve, the traditional ISMS approach has become inadequate in meeting the demands of contemporary cybersecurity programs [3]. Information security refers to the protection of security characteristics of information, such as confidentiality, integrity, and availability [4]. Cybersecurity is the protection of the cyber environment and the assets of organizations and users through a collection of tools, policies, guidelines, best practices, technologies, training, and more [5, 6]. While these two terms overlap, they are not synonymous and should not be used interchangeably. Information security focuses on protecting information (as an

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution-NonCommercial License (https://creativecommons.org/licenses/by-nc/4.0/), which permits non-commercial re-use, distribution, and reproduction in any medium, provided the original work is properly cited. For commercial re-use, please contact reprints@oup.com for reprints and translation rights for reprints. All other permissions can be obtained through our RightsLink service via the Permissions link on the article page on our site-for further information please contact journals.permissions@oup.com

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

asset) from threats and vulnerabilities [7], whereas cybersecurity involves the protection of cyberspace itself, the entities (individuals, organizations, or nations) that function within it, and any of their assets that can be accessed via it [5]. Information security, originally conceived in the 1970s, did not account for the wide range of threats introduced by the rapid evolution of the Internet. The shift in focus from a fraud-centric view of information security to addressing Internet-borne threats in cybersecurity highlights the need to transform the ISMS into a Cybersecurity Management System (CSMS).

Existing security standards, frameworks, and models have been updated over the years, collectively forming an important and valuable body of knowledge. However, they differ in structure, objectives, terminology, and concepts, making the integration of multiple security standards a complex and time-consuming task [8]. There is a lack of a universal, hierarchically structured cybersecurity model that effectively manages and comprehensively measures cybersecurity programs [9]. Another challenge in cybersecurity management is the unclear connection between the cybersecurity program and business goals and objectives. Achieving real success for the security program—the protection of the business services and information—is often elusive, resulting in system disruptions and data breaches.

In response to these challenges, we propose a holistic and structured process model to guide and measure the establishment and ongoing management of a cybersecurity program. Measuring process maturity aids in identifying the strengths and weaknesses of processes [10]. While providing management with a useful perspective on the reliability of the cybersecurity program, process maturity does not offer sufficient insight into the effectiveness of security controls within those processes. Therefore, our model incorporates both an assessment of process maturity and an assessment of control effectiveness to provide a comprehensive perspective. The combined approach of measuring maturity and effectiveness addresses the shortcomings of using a single approach and helps stakeholders make more informed and effective security decisions for managing cybersecurity programs.

We summarized and synthesized critical processes for cybersecurity management to develop the initial process model, based on multiple common security standards, including COBIT, NIST CSF, ISM3, and ISO 27022. To validate the model, we conducted a modified Delphi study, gathering insights from cybersecurity experts. Following this, we incorporated both maturity assessment and effectiveness measurement into the model. The use of attributes links security processes to business services, ensuring alignment between cybersecurity programs and business objectives. Our research enhances the theoretical knowledge in cybersecurity management by identifying critical security processes across strategic, tactical, and operational layers. Additionally, it can be used as a reference guide for cybersecurity stakeholders to establish and continuously improve cybersecurity programs. Furthermore, it increases the understanding of measuring CSMSs by introducing a dual-measurement approach covering process maturity and control effectiveness. This approach helps organizations comprehensively evaluate their cybersecurity programs' performance to identify and address deficiencies, thereby enhancing cybersecurity assurance.

The rest of the paper is organized as follows. The next section provides an overview of the research background, followed by the research methodology. Then, we describe the cybersecurity processes across strategic, tactical, and operational layers and introduce our Cybersecurity Management and Performance Assessment (CSMPA) tool. After that, we discuss the research contributions and limitations. Finally, we make concluding remarks.

Research background

Building security management systems

The traditional approach for organizations to protect their systems and information is to establish and operate an ISMS based on security standards and guidelines. For example, ISO 27001 is a widely used standard for information security management, initially introduced in 1995 as BSI standard BS7799. This standard includes a set of information security controls and control objectives, outlining how to set up an ISMS at a high level [1].

The US Government published its own set of security controls for US federal agencies as NIST Special Publication 800–53: Recommended Security Controls for Federal Information Systems in February 2005 [11]. As with ISO27001, this standard has been regularly updated, and in its fifth revision it was retitled Security and Privacy Controls for Information Systems and Organizations [2]. In 2014, NIST published a cyber-centric standard called the NIST Cybersecurity Framework (CSF), consisting of five core functions: Identify, Protect, Detect, Respond, and Recover, each of which contains multiple categories and subcategories [12]. It provides macro guidance on managing and reducing cybersecurity risks, leaving the specifics of the implementation to organizations [13]. The NIST CSF has become a widely accepted approach to managing cyber risks and was updated in 2024 with a new function, Governance [14]. It is not a stand-alone cybersecurity management solution and often needs to be used in conjunction with additional standards that include detailed controls and processes.

The Information Systems Audit and Control Association published the Control Objective for Information Technologies (COBIT) standard in 1996. The latest version of this standard (COBIT 2019) provides control guidance across the full spectrum of IT, with information security included in areas such as APO13: Managed Security under Align, Plan, and Organize, and DSS05: Managed Security Services under Deliver, Service, and Support [15]. The COBIT control objectives also provide 10 management practices that cover information security. However, it does not adequately address operational aspects of cybersecurity, such as incident response, threat detection, and vulnerability management.

Apart from extant security standards and guidelines, Santos-Olmo et al. [16] identified 11 desirable characteristics for implementing an ISMS in Small and Medium Enterprises (SMEs). However, these features need to be updated to address the current cybersecurity threats facing the SME sector, as the study is over a decade old. Haufe et al. [17] determined the criteria for ISMS core processes and identified 10 ISMS core processes by surveys. Although their research is a good starting point, it fails to address key cybersecurity processes such as event monitoring and identity and access management. It focuses more on auditing than cyber threats. Polkowski and Dysarz [18] conducted a case study to identify the critical security issues for SMEs in Poland in terms of types of targets, types of attackers, and legal issues and provided recommendations on security management. Their study focuses more on discussing existing security issues rather than how they can be solved by enhancing cybersecurity management.

Table 1 below compares our model and the security management literature in performance assessment. NIST CSF defines four Tiers: Partial, Risk-Informed, Repeatable, and Adaptive, to describe the level of rigor with which an organization manages its cybersecurity risks, but the Tiers do not represent maturity levels [14, 19]. Only COBIT provides functionality to assess performance in terms of maturity and effectiveness; however, its primary focus is on IT governance and risk management rather than cybersecurity management.

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

Table 1. Comparison between our model and the security management literature in performance assessment.

Standard/author	Description	Performance assessment	
		Maturity	Effectiveness
ISO 27001:2022 [1]	ISO 27001 specifies the compliance-focused requirements on how to establish, implement, maintain, and improve an ISMS.	Not included in ISO 27001.	
NIST Special Publication 800–53 [2]	NIST SP 800–53 is a guideline for federal agencies to select and specify security controls for more secure information systems.	Not included in NIST SP 800–53.	
NIST Cybersecurity Framework [14]	NIST CSF is a set of cybersecurity principles and best practices for managing and reducing their cybersecurity risks.		
Control Objective for Information Technologies (COBIT) [15]	COBIT provides control guidance for managing and governing IT systems, part of which also involves information security.	Six maturity levels: nonexistent, *ad hoc*, repeatable, defined process, managed and measurable, optimized.	Performance metrics are designed for evaluating the effectiveness of IT processes and controls.
Santos-Olmo *et al*. [16]	Santos-Olmo *et al*. [16] identified 11 desirable characteristics for the implementation of an ISMS to SMEs based on the ISO 27001.	Not included.	
Haufe *et al*. [17]	Haufe *et al*. [17] proposed a framework that encompasses ten core processes of an ISMS.	Not included.	
Polkowski and Dysarz [18]	Polkowski and Dysarz [18] identified critical security issues for Polish SMEs and gave suggestions for security management.	Not included.	
Our Model	We developed a comprehensive and structured cybersecurity management process model with performance assessment, consisting of 6 strategic processes, 11 tactical processes, and 19 operational processes.	Six maturity levels: nonexistent, initial, informal, defined, managed and measurable, optimized.	Measuring effectiveness is performed through security attributes. Each process in our model includes a group of security controls, each of which is associated with a set of security attributes.

Measuring maturity

Maturity model is a widely used concept in security that plays a central role in security management systems [20]. The security maturity model is designed to systematically assess the current state of security in an organization [21]. The Systems Security Engineering Capability Maturity Model (SSE-CMM), published in 1995, was an early security maturity model that was subsequently adopted by ISO as ISO/IEC 21827:2008 [22]. This standard describes the five maturity levels (namely, Performed Initially; Planned and Tracked; Well-Defined; Quantitatively Controlled; and Continuously Improving) as Generic Practices and defines 11 base security processes and 11 project-related processes aiming to advance security engineering as a defined, mature and measurable discipline [22].

The Open Group released the Information Security Management Maturity Model (ISM3) in 2011 and updated it in 2017. The ISM3 covers many of the information security specific objectives that appear in ISMS standards (such as Backup and Access Control) and addresses some of the organization-wide processes (such as Personnel Training and Procurement Management). ISM3 uses the naming convention Initial, Managed, Defined, Controlled, and Optimized to describe its five levels of maturity [23]. These are closely aligned with the SSE-CMM maturity levels. While the SSE-CMM is restricted in scope, the ISM3 has broader coverage of security programs from the strategic, tactical, and operational layers.

Apart from the above maturity models published by industry organizations, researchers have also undertaken several academic studies on security maturity models. Al-Matari et al. [24] proposed a maturity model (on a scale of 1–5) to measure organizations' security maturity level based on automated security controls and the type of controls from ISM3, but their work does not address how to measure control effectiveness. Drivas et al. [10] developed a cybersecurity maturity self-assessment framework specifically for critical national infrastructures, consisting of 20 security requirements across 6 maturity levels. However, their framework did not include specific security controls. Aliyu et al. [25] designed a cybersecurity assessment tool for Higher Education Institutions in the UK comprising 15 security categories (covering both security and privacy regulations) with 6 maturity levels, but it is only applicable to the higher education sector. Le and Hoang [26] designed a cloud security capability maturity model with maturity levels 0–3 to provide a quantitative assessment but their security metrics did not involve various stakeholders and components of cloud security systems. Rosmiati et al. [27] used the entire clause of ISO 27001 in combination with SSE-CMM to measure an organization's maturity level but they did not consider other security standards. Nasser et al. [28] developed a maturity model based solely on ISO 27001, using a fuzzy Analytic Hierarchy Process (AHP) to assess information systems in uncertain environments. However, their model does not address measuring the effectiveness of the controls.

Measuring effectiveness

ISO 27004 provides guidelines for organizations to measure the effectiveness of an ISMS by applying performance measures and effec-

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

Table 2. Delphi study expert profile.

Expert	Role	Industry	Years of experience
1	CISO	Beverage	24+
2	CISO	IT security services	26+
3	CISO	Public administration and safety	24+
4	Cybersecurity Director	Government	27+
5	Cybersecurity Director	Government	19+
6	Chief Technology Officer	IT security services	16+
7	CISO	IT services	34+
8	Cybersecurity Manager	Highways and railways	18+
9	CISO	Financial services	17+
10	Cybersecurity Director	IT services	37+
11	Cybersecurity Manager	Software	14+
12	CISO	IT services	26+

tiveness measures [29]. Boehmer [30] demonstrated that key performance indicators of effectiveness and efficiency can be used to measure the performance of an ISO 27001-based ISMS, but their study lacked empirical validation. Liu and Zhu [31] summarized a list of security responsibilities and their associated security measures for departments involved in information security management to assess the effectiveness of security controls. However, defining departmental security responsibilities is based on the information security standard ISO27002, published in 2005, which is not applicable to the current diverse organizational structures. Nancylia et al. [32] highlighted that the international standards for ISMSs (ISO/IEC 27000 series) should include guidance on measuring the effectiveness of ISMS. They presented a high-level measurement design using a concurrent embedded mixed approach, illustrating how to perform ISMS measurements based on ISO 27001 and ISO 27004. However, their study did not address, which security domains should be evaluated. Bernik and Prislan [33] proposed a model consisting of 10 success factors to measure the performance of information security. However, the success factors are not sufficient to comprehensively measure an ISMS, as they overlook essential aspects such as security planning and threat intelligence.

Research methodology

We used the modified Delphi method in our study, a structured survey approach designed to solve complex problems by repeatedly soliciting the opinions of a panel of experts and achieving an acceptable consensus [34, 35]. This method prevents the biases of an individual participant from influencing the results [36]. Anonymity also encourages creativity and avoids socio-psychological stress on group members, and generally results in higher response rates [37]. The experts for this study were cybersecurity managers with substantial professional experience selected based on the following criteria: (1) Chief Information Security Officer or equivalent position managing the organization's cybersecurity; (2) having at least 10 years of experience in the field of cybersecurity; and (3) being well recognized by the industry, such as a speaker at a leading conference or an author of a prestigious publication [38]. Egfjord and Sund [39] recommended that panels for Delphi studies should include 10–15 participants, therefore, 12 experts were identified for this study through a snowball sampling method [40]. We first conducted background checks on speakers at leading cybersecurity conferences and authors of notable publications using publicly available information (e.g. LinkedIn profiles) to screen candidates who met the criteria. We then contacted these candidates while also accepting referrals of potential participants from their networks who met the criteria, until we recruited 12 respondents for the study (see Table 2).

In the first phase, we conducted a literature review on cybersecurity management. By synthesizing cybersecurity domains from common security standards (COBIT, NIST CSF, ISM3, and ISO 27022), we developed the initial process model. Semistructured interviews were then conducted with experts to collect feedback on the model, including its structure and elements. This approach offered interviewees sufficient room for expression, thereby facilitating the development of more valuable insights related to the topic [41]. Open-ended questions were designed to gather their perspectives on security processes, model design and performance assessment methods. Experts provided feedback on the candidate security processes in the initial process model and were also allowed to propose additional processes. Each interview was held online and lasted ∼1 hour. All interviews were recorded and transcribed [42]. Using thematic analysis [43], we aggregated data to identify themes and subcategories, merging processes with containment relationships and removing duplicates. This phase resulted in a list of 40 candidate security processes.

In the second phase, we sent the process list developed in the first round to the experts, asking them to rate each process on a five-point Likert scale according to its importance to the management of a cybersecurity program (1 = very unimportant to 5 = very important), and to provide further feedback. We analysed ratings using mean, median, standard deviation, and interquartile range to examine central tendency and dispersion. The process list was subsequently modified based on expert input. For example, *Information Quality Assurance*, *Managing the IT Environment*, and *Security Procurement* were removed; *Security Monitoring and Incident Response* were divided into two separate processes (*Security Monitoring* and *Incident Response*); and *Vulnerability Scanning* and *Patch Management* were merged into *Vulnerability Management*.

During the last phase, we repeated the steps of the second phase, sending the revised list to experts for validation to reevaluate the processes that were not in consensus [38]. A total of 10 participants' responses were received in this round. According to Gracht [37], the interquartile range is a measure of the dispersion of the median and is a commonly used and accepted objective measure for determining consensus in Delphi studies. An interquartile range of ≤1 means that more than 50% of the opinions fall within 1 point of the scale and is generally used as a consensus criterion for a 5-unit scale [44–46]. Therefore, the selection criteria for this study were the interquartile range ≤1 and the median score ≥4. In this phase, *Cyber Insurance Management* was deleted, and *Cyber Threat Intelligence* was renamed to *Maintain Threat Intelligence*. Finally, we identified 36 cy-

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

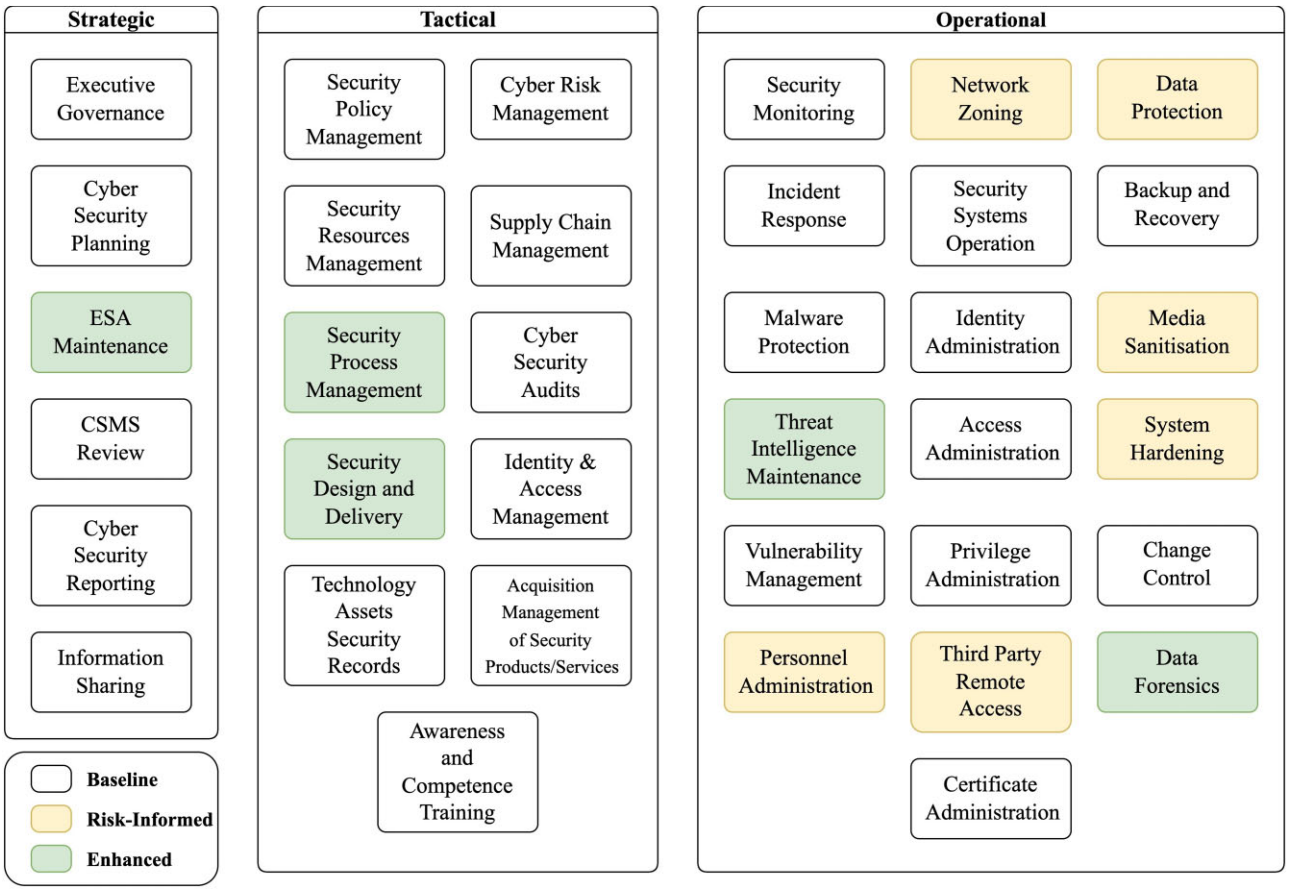


Figure 1. Cybersecurity management process model.

Table 3. Process categories (developed by the authors).

Process category	Description
Baseline	Baseline processes are the fundamental processes considered necessary to be in place in a security program.
Risk-informed	Risk-informed processes are required for the mitigation of identified risks. These processes should be in place when justified by the risk level.
Enhanced	Enhanced processes are used to provide more robust defence, where there are advanced cyber threats. These are optional processes that can be included as the overall cybersecurity maturity increases.

bersecurity processes that met the criteria. Table A1 of Appendix A presents the results of Round 3.

Cybersecurity management process model

Based on the Delphi study, we identified 6 strategic processes, 11 tactical processes, and 19 operational processes. Figure 1 illustrates the high-level cybersecurity management process model, where the definition of each process is summarized in Appendix B. As shown in Fig. 1, we also classify the processes into three categories: basic, risk-informed, and enhanced in accordance with definitions in Table 3. This helps organizations prioritize security processes when resources are limited. Table C1 in Appendix C shows the standards mapping, illustrating the relationships between our process model and common security standards (COBIT, NIST CSF, ISM3, and ISO 27022). To ensure the reliability and validity of the results, two researchers independently completed the initial standards mapping. The results were then cross-checked through multiple rounds of comparison and group discussion, followed by revisions and a final review to resolve any inconsistencies or disagreements. Due to the large number of security processes, we discussed only the major findings as follows.

Strategic processes

Strategic processes provide cybersecurity governance to ensure that low level security services are effective and delivered within acceptable cost and risk parameters [23]. Our model spans six strategic processes, namely, executive governance, cybersecurity planning, CSMS review, Enterprise Security Architecture (ESA) maintenance, cybersecurity reporting, and information sharing.

Executive governance is an essential strategic process that defines and approves cybersecurity roles, responsibilities, and authorities, and enables cybersecurity governance for the organization. One expert concurred and enumerated the necessary measures to establish ongoing governance: “What gives this department the cybersecurity function of an organization? What is the mandate of that

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

organization? What are the key roles and responsibilities that the department has the authority to carry out? How does cybersecurity play its role across other non-cybersecurity functions?" Another expert emphasized that the key to successful governance is obtaining timely feedback and communication from other departments, "one of the things I've noticed in cybersecurity over the years is that we have governance, but we tend to tell people what to do and sometimes it doesn't work. So, what I'm tending to do now is pushing a lot of the cyber back towards the business and other functions in IT. Rather than telling people what to do, have them come back and give [us] feedback."

Cybersecurity reporting includes regular updates to the Executive on the progress of cybersecurity plans and the security posture. It is a channel of communication with executives, thereby facilitating strategic decision making. One participant discussed how to achieve an effective reporting function, "I think reporting, by itself, could be taken more strategically as a communication tool with the Executive Management. When you're doing that, you're basically sharing data and information that could be related to security threats or strategic threats affecting the industry…That would enable better decision making. So, I would encourage you to not just look at reporting as one way communication. I would request you to consider the scope of reporting, and the second thing I would request you to consider is how that information, as received by the Executive Management, influences the strategic decision making. And it's only then that you would consider that reporting function to be effective." Another participant proposed a bottom-up reporting framework, "I've been involved with a reporting architecture, where you start down at your lower layers, collecting data and then incorporating it up into a security incident [and] event monitoring system. Above that, you have a reporting framework that not only takes the specific details out of that layer below it but also starts applying trends and data insights on top. Then you can start doing security forecasting so you could start to see how certain things are increasing."

Cybersecurity planning is considered a core strategic process that includes the development of annual security plans and the associated budget. It should closely align with overarching business objectives to be effective. As one expert explained, "If you're a cybersecurity function and you are not aligned with what the business is doing, then you are not going to be as strategic as you need to be. And again, if I use my company as an example, within the function I sit in, it's very focused on sort of digital and technology, which is great. However, a large part of the business strategy is actually around efficiency and effectiveness in the manufacturing space. So, if I wasn't clear on business objectives in formulating my strategy, there is a risk that you will miss actually a key component of what the business is all about, because we are only focusing on part of what actually matters to the business." Another expert strongly agreed, stressing the importance of enterprise-level planning, "I think when we're talking about planning at this level, we really need to be talking not just from the cyber side, but about how we do this from an enterprise level. So, I think again, it's split into two parts: cyber planning, and enterprise planning for cyber. Because I can plan all I like, but if it's not aligned to anything at the top end, nothing's going to happen."

Information sharing as a strategic process refers to the external strategic sharing of security information (e.g. incidents) with industry and government groups in accordance with agreed-upon policies and procedures. One interviewee emphasized the importance of collaborative settings for information sharing and how the inflow of external information influences strategic decision making, stating that "while you're sharing information, you're equally receiving information about strategic insights, incident security postures, new friends in cyber security… So, your collaboration setup is much more important than information sharing per se… When you have inflow of information, you may not want to stop there alone, because you would probably want to look at it from a perspective of how this information influences my strategic decision making. Because if it does that, then you're at a much higher level of maturity as compared to saying, 'Well I've just received that information,' without much context or much direction around how I'm going to use that information." Another participant affirmed the significance of both internal communication and external collaboration, "There is certainly, from a process maturity perspective, a huge difference between effective internal communications and engagements versus your external collaboration. Now both of them are important and I think the really mature security functions would do both."

Tactical processes

Tactical processes aim to address the design and implementation of CSMS and the management of security resources [23]. Our model comprises 11 tactical processes including supply chain management, cybersecurity audits, awareness and competence training, and security resources management, part of which are discussed as follows.

Supply chain management involves regularly assessing the security posture of third-party suppliers and identifying, prioritizing, and mitigating the risks they pose. Cybersecurity teams can request to review the compliance certifications as well as through questionnaires when assessing a vendor's security status. One expert explained "Have they got a SOC 2 Type 2 report, which means someone has come in and tested their security controls over a long period of time? So, you know that it's designed and operating effectively. You might also ask them for evidence of ISO 27001 certification. And as the organizations haven't had time to do any of that, then you tend to be asked, getting them to fill out security questionnaires based on a known framework and trying to get the answers out of them that way. You want to be able to use it as a filtering process to get rid of vendors that aren't going to meet your security requirements." There are several important measurement factors to consider during the evaluation process, as one expert underlined, "The assessment is also based on the sensitivity of the data that they will be accessing or storing, and how critical that vendor will be to our business as well. So, if it's a critical business banking process, then you don't want small, immature vendors as part of your supply chain."

Cybersecurity audits include operational process audits to check control effectiveness, for instance, annual sample controls testing, penetration testing, and unannounced testing exercises (red team). One participant indicated that they perform internal audits with reference to the ISO 27000 series of standards, "We need to have internal audits in place, so we have an assurance team that takes care of this. We look at what kind of logical controls or technical controls are in place to make sure that whatever data or assets we have, in terms of providing customer support, the actual products, how we develop the products, and so on, everything is adherent to the ISO 27000 standards. So, let's say we are looking at the laptops that we lend to our staff: what kind of controls are in place, how [is] the data within the laptop protected, …, and what kind of protections are in place to prevent any kind of malicious exploitation of the data by an insider?" The frequency and duration of cybersecurity audits are determined by various factors, such as the size of the organization, the complexity and importance of the data, and the availability of resources. One expert suggested that they conducted internal audits followed by external audits on an annual cycle, "For the external audit to happen, my team has to perform the internal audit. It is an

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

annual cycle with internal audits, followed by 6-month external audits, then internal audits next year… and so on and so forth."

Awareness and competence training includes conducting regular cybersecurity awareness training for all users (such as phishing simulations and posters) and providing competence training for security staff to continually improve their professional skills. One expert expressed concern about the cybersecurity awareness of developers and highlighted the importance of security training for this group, "What I find is that security staff in the lead know what training they need, and they actually push for that. People I normally worry about most are developers, okay? Not even general users, but developers. Training for them will save security a lot of difficulties later on. They simply are separate, the security team is separate, the development team is separate, which is fair enough. But there needs to be some crossover by the security team to push for security training for developers." Another interviewee stated that most organizations now conduct phishing training and gave an example of what training on unsolicited emails should cover, "the current thing we all do is in the phishing training, for example, how to identify a dodgy email that comes in. Like when an unsolicited email comes in, and it has a link, and I should not click on that. How to find that link good or bad, how to report that, where to report that, and all that awareness training. The more you do that, the fewer incidents you have to handle later on."

Security policy management refers to developing, implementing, and regularly updating security policies and supporting guidelines, standards, and procedures. One expert emphasized that there should be multiple rounds of review, including technical review and business socialization, before a policy is released: "So, there will be a process in place to review a current policy, reach out to technical stakeholders to have them check for any errors in the current policy or changes that have occurred in the previous 12 months or in the previous cycle, and suggest updates. That will go through a technical review as a step, and then after the technical review, it needs to be socialized with business stakeholders. It is worth pointing out that it must go through not just the technical details side, but also through the business socialization as well, because quite often you find someone will say, technically we want to make some changes, but the business will have a reason, either why they can't do it or they'll say that it doesn't meet their compliance obligations or something like that. So, there have to be a couple of stages of review before the policy gets finalized and published."

Operational processes

Operational processes are routine security processes designed for the defined goals of cybersecurity protection. Our model consists of 19 operational processes shown in Fig. 1, such as backup and recovery, system hardening and security monitoring, and some of these operational processes are illustrated below.

Backup and recovery involve creating, storing, and testing backups of data, and restoring them in the event of data loss, system failure, or other disruptions. Even though most organizations have backups, as one expert commented, "one of the things people forget to do is they take backups, but they don't actually go in regularly and restore the data to see if it actually is usable. So, testing restore processes is often overlooked." Likewise, another expert affirmed the importance of testing backups: "That's the first thing you are going to have to do if you have a catastrophic issue. So I think it's how bad you think it's going to be, and then—do you actually have a process or a procedure, or at least an informed risk around what you are backing up and recovering from? Testing is a key one, so I think that, yeah, testing of your backups is a crucial one." One participant briefly outlined the impact of backup and recovery, "So, backup and recovery, even though it is falling under the cybersecurity aspect, it is actually an operational activity. It supports cyber because, should anything go wrong, you need to recall all your systems, redeploy your systems. That's the impact or the significance of having a backup and recovery."

System hardening is the process of strengthening the security of systems, applications, and infrastructure by, for example, removing unnecessary services and shutting down unneeded ports. The hardening should comply with vendor recommended practices and industry best practices. One expert advised that the implementation of system hardening needs to be based on a strategy and plan, "You should develop a strategy and plan for remediating system flaws, and this usually needs to be done in phases." Another expert pointed out a common attack surface vulnerability, the use of default credentials, "In system hardening, one thing that often gets missed is removing default configurations. Devices often are issued with admin accounts called 'admin', and admin passwords called 'password'. So, removing default configurations is something that's getting more important these days."

Threat intelligence maintenance is managing threat sources and feeds of indicators of compromise. According to one expert, "We analyze the data collected by threat intelligence to gain a deeper understanding of the various cyber threats." Therefore, security teams can identify threat patterns and deploy more effective security controls in advance. Another participant underlined the importance of threat detection, "How you identify a security threat, how the information flows from a security control over to a detection platform where you're basically ingesting that information or relating that information with intelligence rules. And then you have a detection mechanism. Those alerts are then handled by a security professional, and how a security professional then analyzes that information with the help of the decision support system and takes necessary actions. So, that whole process of threat detection, contextualization, and management of that entire threat is probably one of the most important processes across the organization."

Media sanitization involves managing, executing, and reviewing electronic sanitization procedures to ensure the removal of data from media scheduled for disposal. The process prevents unauthorized access and data breaches. It is an essential part of a data lifecycle policy, however, one participant indicated that the lack of a policy was an issue in the deployment of the process, "one of the things that is required for this process is their data life cycle policy, which basically says, based on classification, based on whatever, how long you're going to keep certain data, and then once that is removed, how it needs to be completely removed. Then, depending on what media it's on and the data sensitivity, how we are going to sanitize that. If you don't even have a policy, then you're never going to be able to do that, so the lack of policy is where I find a problem there."

CSMPA tool

Based on the findings of the Delphi study, we developed the CSMPA tool (available at shorturl.at/bjFdr). A user guide is provided in the Supplementary material. This tool enables the assessment of each security process's performance in terms of maturity and effectiveness.

Maturity is a process-centric measure and can be assessed by checking whether an existing process meets a defined maturity level. Our model uses six maturity levels to measure process maturity: nonexistent, initial, informal, defined, managed, and optimized.

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

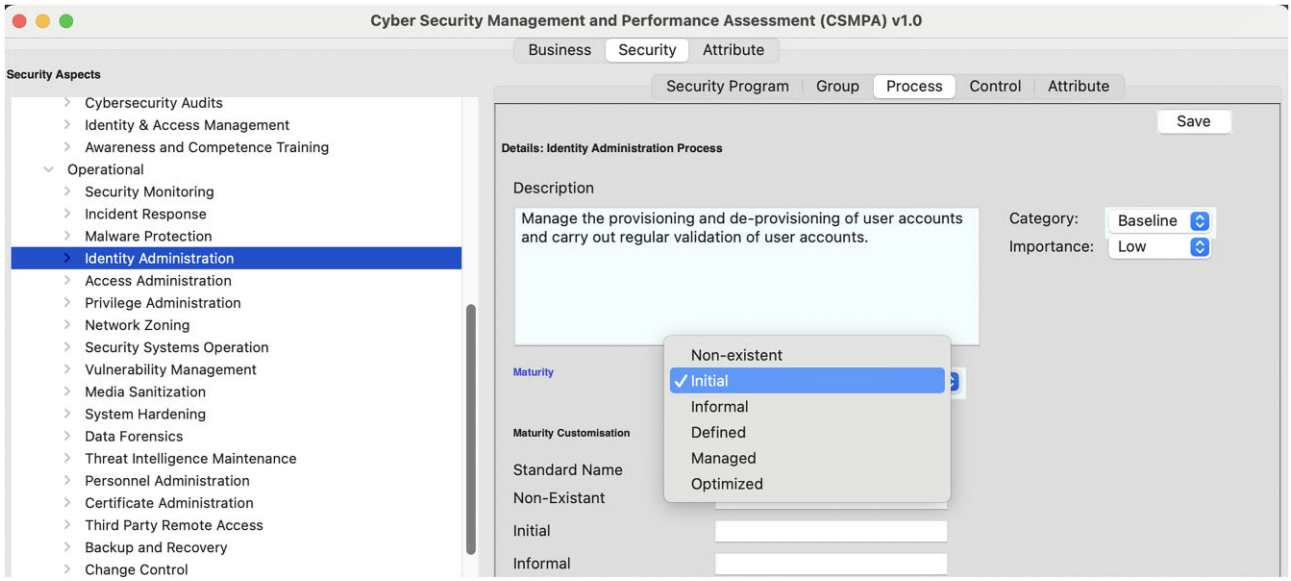


Figure 2. Maturity assessment of the CSMPA tool.

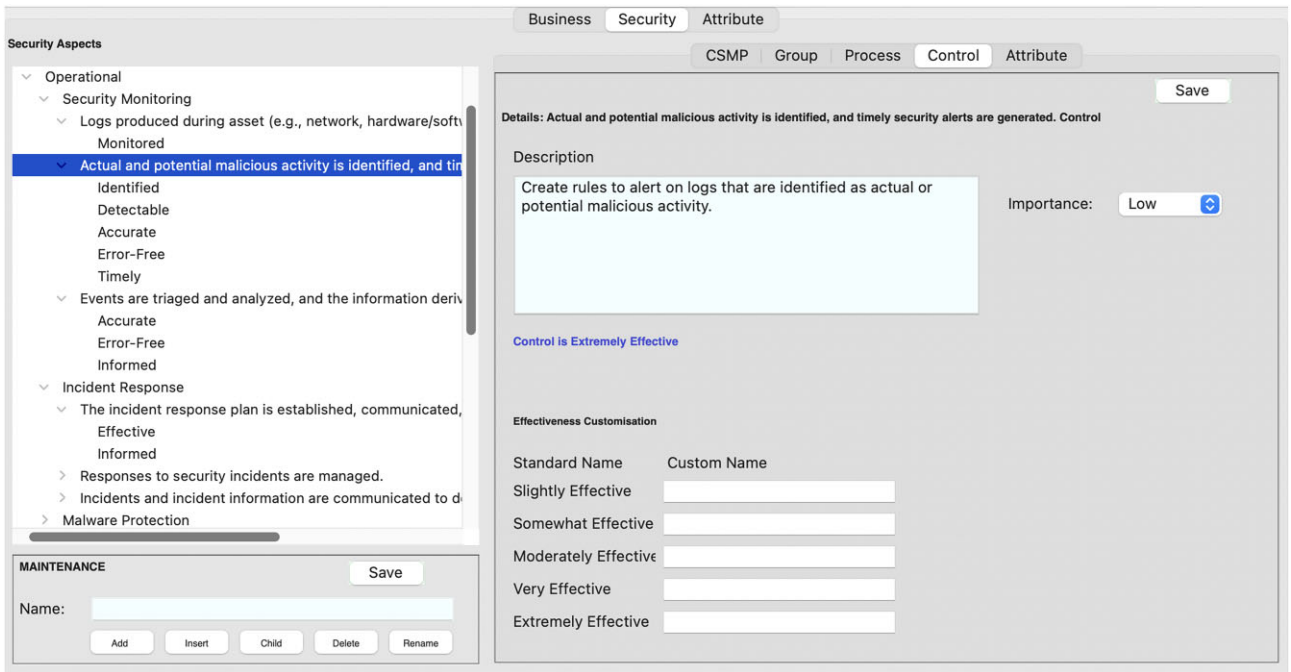


Figure 3. Processes, controls, and attributes of the CSMPA tool.

Table D1 in Appendix D shows the definition of each maturity level. As illustrated in Fig. 2, the user is required to enter a maturity level for each process. Each process is assigned a weight in the initial stage of the assessment to reflect the importance of that process. The weighted average of all security processes is the overall process maturity level.

The effectiveness of cybersecurity controls is measured by security attributes. According to the SABSA Enterprise Security Architecture Framework [47], security attributes represent the atomic elements of security required to ensure the delivery of business outcomes. They provide a common language through which the business can request security services, and the cybersecurity team can deliver them. Security attributes should be reflected upwards into the relevant business objectives and downwards into the security controls that provide the required attribute protection. Thus, each process in our model contains a set of security controls, each associated with a set of security attributes, as shown in Fig. 3. The effectiveness of all security attributes at the security control level is assessed first, and aggregated upwards to calculate the effectiveness of each security process, which ultimately leads to the overall effectiveness of all security processes. All the formulas for calculating effectiveness levels are summarized in the Supplementary material, which is also available at shorturl.at/bjFdr (see page 14 of the user guide).

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

Discussions

This paper utilizes the Delphi method to develop a holistic process model for cybersecurity management and provides a measurable CSMPA tool for cybersecurity stakeholders. Our study makes several significant academic contributions. First, we introduce a hierarchical cybersecurity management process model, with each process including its associated security controls. The model addresses the management and measurement of a cybersecurity program from tactical, strategic, and operational perspectives. It fills an academic gap by offering a structured and systematic approach to effectively managing cybersecurity programs.

Second, our research presents a set of critical cybersecurity management processes that shift the focus from traditional information security to cybersecurity, fulfilling the requirements of contemporary cybersecurity management. These security processes increase the understanding of establishing a process-centered cybersecurity management program, which enriches the cybersecurity management literature.

Third, we perform a comprehensive synthesis of four dominant security standards (COBIT, NIST CSF, ISM3, and ISO 27022), resolving conceptual fragmentation by establishing cross-standard mappings (as shown in Table C1 of Appendix C). This integration provides researchers with a unified taxonomy for analysing security processes. Notably, we adopt a rigorous validation protocol that includes dual-coder independent analysis and iterative consensus-building to ensure the reliability of standards mappings. Additionally, we present a two-dimensional joint assessment of security program performance, maturity, and effectiveness, through our CSMPA tool. This expands existing security standards and models for evaluating the performance of security programs.

This study also makes substantial contributions to the practical aspects of cybersecurity management. First, following solely a single security management standard may not fully meet an organization's cybersecurity management requirements. Experts highlight that there are overlaps and correlations between security standards and integrating them often requires substantial resources and time. Our model provides a structured approach to help practitioners integrate these standards more efficiently. Organizations can refer to our mapping of common security management standards (such as COBIT and NIST CSF) to review whether their security processes and controls are compliant with these standards, helping to reduce labor and financial costs required for this work.

Second, Nasser, Al-Khulaidi [28] emphasizes assessment as the priority of cybersecurity management. We extend theoretical model into measurable practice through the CSMPA tool, which operationalizes two essential dimensions of cybersecurity performance: process maturity and control effectiveness. Rather than relying on a single evaluation method, our CSMPA tool can be used to assess the performance of an organization's cybersecurity program in terms of both maturity and effectiveness. This helps organizations analyse the current state of cybersecurity management implementation, identify strengths, deficiencies, and future security priorities, and provide direction for decision making and strategy planning to continuously optimize cybersecurity management.

Lastly, our model has a distinctive macro design that connects cybersecurity management with the broader organizational context by drawing on the SABSA framework [47]. This design ensures that cybersecurity programs are closely aligned with business goals and objectives, effectively bridging the gap between cybersecurity practices and organizational needs, while enhancing the assurance and alignment of security processes. In doing so, we provide a common language that maps technical standards to business objectives, making cybersecurity more accessible across different organizational levels. By seeking insights from CISOs or equivalent roles, who typically operate at the intersection of business and security, our model offers a lightweight approach to building an enterprise security architecture.

Like all other studies, this research has limitations that provide opportunities for future research. The scope of the proposed CSMPA tool may be too broad for small businesses, given the limited resources typically available to them. Additionally, it is generic rather than tailored to a particular sector or business type. Further case studies are needed to explore how factors, such as company type, sector, and infrastructure architecture influence the model's application.

Conclusion

This paper presents a hierarchical cybersecurity management process model based on findings from three rounds of a modified Delphi study, which identifies and categorizes 36 critical processes across three tiers: 6 strategic, 11 tactical, and 19 operational processes. Building on this model, we introduce the CSMPA tool, designed to help security stakeholders systematically manage cybersecurity programs while comprehensively evaluating both process maturity and control effectiveness. Our research contributes to the cybersecurity management literature and provides practitioners with a blueprint for establishing and managing measurable cybersecurity programs aligned with business objectives.

Acknowledgment

We thank the anonymous reviewers for their valuable comments, which have helped us improve the content, organization, and presentation of this paper.

Author contributions

Marina Liu (Conceptualization [lead], Data curation [lead], Formal Analysis [lead], Methodology [lead], Writing – original draft [lead], Writing – review & editing [lead]), Malcolm Shore (Conceptualization [supporting], Methodology [supporting], Supervision [supporting], Writing – original draft [supporting], Writing – review & editing [supporting]), William Yeoh (Conceptualization [supporting], Methodology [supporting], Supervision [lead], Writing – review & editing [supporting]), Frank Jiang (Conceptualization [supporting], Supervision [lead], Writing – review & editing [supporting]), and Sherali Zeadally (Methodology [supporting], Writing – review & editing [supporting])

Supplementary data

Supplementary data is available at *Journal of Cybersecurity* online.

Conflict of interest: None declared.

Funding

None declared.

References

1. ISO. *Information Security, Cybersecurity and Privacy Protection—Information Security Management Systems—Requirements*. Geneva. https://www.iso.org/standard/82875.html (3 June 2024, date last accessed).
2. NIST. *Security and Privacy Controls for Information Systems and Organizations*. Gaithersburg. https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final (17 July 2024, date last accessed).
3. Susukailo V, Opirsky I, Yaremko O. Methodology of ISMS establishment against modern cybersecurity threats. In: Klymash M, Beshley M, Luntovskyy As (eds), *Proceedings of the Fourteenth IEEE International Conference on Advanced Trends in Radio electronics*. Slavske: Springer, 2018, 257–71.

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026

4. ISO. *ISO/IEC 27002: Code of Practice for Information Security Management*. Geneva. https://www.iso.org/standard/50297.html (5 April 2025, date last accessed).
5. Solms RV, Niekerk JV. From information security to cyber security. *Comput Secur* 2013;**38**:97–102.
6. Althonayan A, Andronache A. Shifting from information security towards a cybersecurity paradigm. In: *Proceedings of the 2018 Tenth International Conference on Information Management and Engineering*. Salford: Association for Computing Machinery, 2018, 68–79. https://doi.org/10.1145/3285957.3285971
7. Reid R, Niekerk JV. From information security to cyber security cultures. In: *Proceedings of the 2014 Information Security for South Africa*. Piscataway, NJ: IEEE, 2014, 1–7.
8. Taherdoost H. Understanding cybersecurity frameworks and information security standards—a review and comprehensive overview. *Electronics* 2022;**11**:2181. https://doi.org/10.3390/electronics11142181
9. Savas S, Karatas S. Cyber governance studies in ensuring cybersecurity: an overview of cybersecurity governance. *Int Cybersecur Law Rev* 2022;**3**:7–34. https://doi.org/10.1365/s43439-021-00045-4
10. Drivas G, Chatzopoulou A, Maglaras L. *et al.* A NIS directive compliant cybersecurity maturity assessment framework. In: *Proceedings of the 2020 IEEE Forty-Fourth Annual Computers, Software, and Applications Conference (COMPSAC)*. Madrid: IEEE, 2020, 1641–6. https://doi.org/10.1109/COMPSAC48688.2020.00-20
11. NIST. *Recommended Security Controls for Federal Information Systems*. Gaithersburg. https://csrc.nist.gov/publications/detail/sp/800-53/archive/2005-06-17 (17 July 2024, date last accessed).
12. NIST. *Cybersecurity Framework*. Version 1.0. Gaithersburg. https://www.nist.gov/cyberframework/framework-documents (17 July 2024, date last accessed).
13. Gordon LA, Loeb MP, Zhou L. Integrating cost–benefit analysis into the NIST cybersecurity framework via the Gordon–Loeb model. *J Cybersecur* 2020;**6**. https://doi.org/10.1093/cybsec/tyaa005
14. NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg. https://www.nist.gov/cyberframework (17 July 2024, date last accessed).
15. ISACA. *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg. https://store.isaca.org/s/store#/store/browse/detail/a2S4w000004Ko5aEAC (2024 7 June, date last accessed).
16. Santos-Olmo A, Sánchez LE, Fernández-Medina E. *et al.* Desirable characteristics for an ISMS oriented to SMEs. In: *Proceedings of the Eighth International Workshop on Security in Information Systems (WOSIS11)*. Beijing: SciTePress, 2011, 151–8.
17. Haufe K, Colomo-Palacios R, Dzombeta S. *et al.* ISMS core processes: a study. *Proc Comput Sci* 2016;**100**:339–46. https://doi.org/10.1016/j.procs.2016.09.167
18. Polkowski Z, Dysarz J. IT security management in small and medium enterprises. *Sci Bull Econ Sci* 2017;**16**:134–48.
19. NIST. *Cybersecurity Framework*. Version 1.1. Gaithersburg. https://www.nist.gov/cyberframework/framework-documents (17 July 2024, date last accessed).
20. Schmitz C, Schmid M, Harborth D. *et al.* Maturity level assessments of information security controls: an empirical analysis of practitioners assessment capabilities. *Comput Secur* 2021;**108**:102306.
21. Rabii A, Assoul S, Ouazzani Touhami K. *et al.* Information and cyber security maturity models: a systematic literature review. *Inf Comput Secur* 2020;**28**:627–44.
22. ISO. *Information Technology—Security Techniques—Systems Security Engineering—Capability Maturity Model (SSE-CMM)*. Geneva. https://www.iso.org/standard/44716.html (3 June 2024, date last accessed).
23. OpenGroup. *Open Information Security Management Maturity Model (O-ISM3)*. Version 2.0. San Francisco. https://publications.opengroup.org/c17b?_ga=2.99004061.2002443395.1671458540-17608643.1670157460 (7 June 2024, date last accessed).
24. Al-Matari OMM, Helal IMA, Mazen SA. *et al.* Adopting security maturity model to the organizations' capability model. *Egypt Inf J* 2021;**22**:193–9. https://doi.org/10.1016/j.eij.2020.08.001
25. Aliyu A, Maglaras L, He Y. *et al.* A holistic cybersecurity maturity assessment framework for higher education institutions in the United Kingdom. *Appl Sci* 2020;**10**:3660, https://doi.org/10.3390/app10103660
26. Le NT, Hoang DB. Capability maturity model and metrics framework for cyber cloud security. *Scalable Comput* 2017;**18**:277–90.
27. Rosmiati RI, Prayudi Y. A maturity level framework for measurement of information security performance. *Int J Comput Appl* 2016;**141**:975–8887.
28. Nasser A, Al-Khulaidi A, Aljober M. Measuring the information security maturity of enterprises under uncertainty using fuzzy AHP. *IJITCS* 2018;**10**:10–25. https://doi.org/10.5815/ijitcs.2018.04.02
29. ISO. *Information Technology—Security Techniques—Information Security Management—Monitoring, Measurement, Analysis and Evaluation*. Geneva. https://www.iso.org/standard/64120.html (2024 3 June, date last accessed).
30. Boehmer W. Appraisal of the effectiveness and efficiency of an information security management system based on ISO 27001. In: *Proceedings of the 2008 Second International Conference on Emerging Security Information, Systems and Technologies*. Cap Esterel: IEEE, 2008, 224–31. https://doi.org/10.1109/SECURWARE.2008.7
31. Liu H, Zhu Y. Measuring effectiveness of information security management. In: *Proceedings of the 2009 International Symposium on Computer Network and Multimedia Technology*. Wuhan: IEEE, 2009, 224–31.
32. Nancylia M, Mudjtabar EK, Sutikno S. *et al.* The measurement design of Information Security Management System. in: *Proceedings of the Eighth International Conference on Telecommunication Systems Services and Applications (TSSA)*. Bali: IEEE, 2014, 1–5.
33. Bernik I, Prislan K. Measuring information security performance with 10 by 10 model for holistic state evaluation. *PLoS One* 2016;**11**:1–33. https://doi.org/10.1371/journal.pone.0163050
34. Keil M, Lee HK, Deng T. Understanding the most critical skills for managing IT projects: a Delphi study of IT project managers. *Inf Manag* 2013;**50**:398–414.
35. Salas WH. Model to improve an ERP implementation based on agile best practice: a Delphi study. *Proc Comput Sci* 2023;**219**:1785–92. https://doi.org/10.1016/j.procs.2023.01.474
36. Okoli C, Pawlowski SD. The Delphi method as a research tool: an example, design considerations and applications. *Inf Manag* 2004;**42**:15–29.
37. Gracht HAvd. Consensus measurement in Delphi studies: review and implications for future quality assurance. *Technol Forecast Soc Change* 2012;**79**:1525–36. https://doi.org/10.1016/j.techfore.2012.04.013
38. Yeoh W, Liu M, Shore M. *et al.* Zero trust cybersecurity: critical success factors and a maturity assessment framework. *Comput Secur* 2023;**133**:103412.
39. Egfjord KF-H, Sund KJ. A modified Delphi method to elicit and compare perceptions of industry trends. *MethodsX* 2020;**7**:1–10. https://doi.org/10.1016/j.mex.2020.101081
40. Creswell JW, Creswell JD. *Research Design : Qualitative, Quantitative, and Mixed Methods Approaches*. Los Angeles, CA: SAGE, 2018,
41. Adeoye-Olatunde OA, Olenik NL. Research and scholarly methods: semi-structured interviews. *J Am Coll Clin Pharm* 2021;**4**:1358–67. https://doi.org/10.1002/jac5.1441
42. Nugraha Y, Martin A. Cybersecurity service level agreements: understanding government data confidentiality requirements. *J Cybersecur* 2022;**8**. https://doi.org/10.1093/cybsec/tyac004
43. Braun V, Clarke V. Reflecting on reflexive thematic analysis. *Qual Res Sport Exercise Health* 2019;**11**:589–97. https://doi.org/10.1080/2159676X.2019.1628806
44. Rayens MK, Hahn EJ. Building consensus using the policy Delphi method. *Pol Polit Nurs Pract* 2000;**1**:308–15.
45. Raskin MS. The Delphi study in field instruction revisited: expert consensus on issues and research priorities. *J Soc Work Educ* 1994;**30**:75–89. https://doi.org/10.1080/10437797.1994.10672215
46. Vet ED, Brug J, Nooijer JD.. *et al.* Determinants of forward stage transitions: a Delphi study. *Health Educ Res* 2005;**20**:195–205. https://doi.org/10.1093/her/cyg111
47. Sherwood J, Clark A, Lynas D. *Enterprise Security Architecture: A Business-Driven Approach*. Boca Raton, FL: CRC Press, 2005. https://doi.org/10.1201/b17776

© The Author(s) 2025. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution-NonCommercial License (https://creativecommons.org/licenses/by-nc/4.0/), which permits non-commercial re-use, distribution, and reproduction in any medium, provided the original work is properly cited. For commercial re-use, please contact reprints@oup.com for reprints and translation rights for reprints. All other permissions can be obtained through our RightsLink service via the Permissions link on the article page on our site-for further information please contact journals.permissions@oup.com

Downloaded from academic.oup.com/cybersecurity/article/11/1/tyaf020/8238597 by guest on 27 October 2026